Privacy Enhancing National Identification Card System

Eric Kuada, Isaac Wiafe, Daniel Addo, Emmanuel Djaba
School of Technology
Ghana Institute of Management and Public Administration
Accra, Ghana

***Abstract*— This paper argues that the privacy concerns that are associated with national identification systems is because of the failure of various countries to implement national identification systems with a strong privacy theory backing the implementation. This work is therefore aimed at addressing the privacy concerns of those countries debating national identification system adoption. Furthermore, the project sought to design and develop a privacy enhancing national identification system that is suitable for implementation at minimal cost per capita to any country. Our proposed privacy enhancing national identification card system was designed and developed based on the control and limitation theory of privacy to achieve the objectives of restricting unauthorized access to information on the identification card, and giving the cardholder control over who has access to information on the identification card.**

Keywords—Identification card; privacy; access revocation; national ID card systems; card verification; privacy theories

I. Introduction

National identification card systems are generally seen to promote timely and efficient services to citizens of a nation. Some advocates argue that it promotes enhanced national security and expose potential criminals and terrorist; for other advocates, it is a means of stemming illegal immigration [1] and aids in combating identity fraud [2]. Several countries like Germany, Egypt, Hong Kong, Malaysia, Belgium, France etc., are using national identification cards. Even though throughout its history, the United States of America has consistently rejected the idea of a national identification system due to concerns of privacy breaches, surveillance and profiling of the American public, the debate is still ongoing in the United States and the United Kingdom with a push by advocates to implement national identification card systems because of the perceived merits mentioned above.

Those not in favour of the deployment of national identification (ID) systems argue that because the basic attributes on an ID card such as staff ID cards, passports, National ID cards, health insurance cards, voter ID cards, etc. are: the name of the bearer, date of birth, photograph, and some uniquely identifying number, this creates serious privacy concerns. Furthermore, in addition to these, recently emerging ID card systems may also include biometric data and RFID tags, which are both highly privacy sensitive technologies which affords an adversary to perform unauthorized (clandestine) scanning and tracking, and eavesdropping [3]. Furthermore, it is not uncommon to see misplaced ID cards displayed at bank premises and other third party identity verification entities' premises; this leads to certain kind of problems such as identity theft, privacy breaches, surveillance [3], and arbitrary or uncontrolled linkage of data about people through automated personal data systems [1]. These concerns therefore call for a privacy enhancing approach to the design and implementation of identification card systems. The cost implications of implementing security and privacy enhanced identification systems are however normally out of the reach of most developing and even developed countries.

A. Problem Statement and Motivation

According to M. J. Quinn, privacy is a social arrangement that allows individuals to have some level of control over who is able to gain access to their physical selves and their personal information [4]. This is supported by the work of Acuisti and Grossklags, where over ninety percent of respondents agree to the definition of privacy being ownership and control of personal information [5]. It is therefore the zone of inaccessibility that surrounds a person and he/she has complete control over determining this boundary of inaccessibility. This definition is also implied by Ingo et al., in their work on "Privacy Features of European eID Card Specifications" [6] [7]. From the perspective of identity management, privacy may be considered to address the four main privacy characteristics of anonymity, psydonymity, unlinkability, and unobservability [8] [9].

Many of the ID system that have been implemented by most countries have similar motives; improve identification and authentication, reduce crime, fight terrorism, prevent identity theft, to make it easier for governments to provide e-services to its citizen, etc. In these developed countries, the ID card of a card bearer is not only used for identification purposes but linked to almost every activity of the card bearer like in Malaysia [14]. With time, these activities of the card bearer could be collated to create a clear profile of him. This raises a major questions that needs to be answered; who has access to view the information of the card bearer and at what point does the verifier have access to these information? Does the card bearer have the right to grant access to or deny anyone access to his information. These problems exist with the ID card system because they have not been designed and implemented based on the theory or concept of privacy. The motivation for undertaking this work is the failure of various countries to implement national ID systems with a strong privacy theory backing the implementation even though there

978-1-5386-2775-4/17/$31.00 ©2017 IEEE

is a collective consensus to have such a system is place. Secondly, it is aimed at addressing the privacy concerns of those debating national identification system adoption. Finally, because the cost implications of implementing security and privacy enhancing national ID card systems are normally out of the reach of most developing and even developed countries, the project seeks to design and develop a national identification system that is suitable for implementation at minimal cost per capita to any country.

II. Literature Review and Theoretical Background

Privacy breaches will normally make room for other privacy problems that are closely related to it. Among these are identity theft and its associated identity fraud on the individual or gang crime level; and profiling and surveillance on the state and governmental agency level.

Identity theft is a crime in which an imposter obtains key pieces of personal identifiable information in order to impersonate someone else. This information can then be used in several fraudulent activities such as obtaining credit, making purchases, and obtaining other services in the name of the victim, or to provide the thief with false credentials. In addition to running up debt, an imposter might use the stolen information to perpetuate damaging defamatory activities on the victim's persona or even provide false identification to police, creating a criminal record or leaving outstanding arrest warrants for the victim whose identity has been stolen [10].

Surveillance is the deliberate monitoring of the activities and behaviour of people with the intent of extracting necessary information for the purposes of managing, influencing, or directing or even sometimes in rare cases protecting them. It is normally a tool used by several governments for intelligence gathering for the purposes of preventing crime, foiling terrorist attacks, protecting entities such as a person, group of people, a process or object. It also comes handy for criminal gangs in the planning and execution of crimes such as in kidnapping and robbery. It normally requires the linkage of data or information from several sources and using specialized tools for analysing them. The gathered information and analysis performed helps to create profiles of entities such as individual persons or a group of people which further facilitates the perpetuation of the surveillance activities in gathering further information.

A. Related work

Across the globe, many countries have either implemented some form of national identification card system or planning to implement one. The motives for this action is often similar among these countries; improve identification and authentication, reduce crime, fight terrorism, prevent identity theft, to make it easier for governments to provides e-services to its citizen, etc. [11][12]. With the advancement in technology, Identification Cards (IDs) have grown from the simple cards with basic information of the card bearer to a more complex card where not only the basic information of the card bearer is stored on the card but additional information such as biometric data. Several technologies are available to support the way information is captured and stored which includes RFID, smart cards, etc. Some argue that, by including some security measures - biometric data, encrypting the data, and securing the channel through which data is transmitted - would help in some way to protect and secure the data of the card bearer which would improve privacy [11][13]. But this is not entirely true. In most countries like Malaysia, the national identification card is used in almost every activity of the card bearer, from shopping to banking [14]. With time, the activities of the card bearer could be collated and used to build a clear profile overview of an individual [15][14]. In some countries like the US and Australia, national identification cards has been perceived as tool for surveillance and their introduction has been resisted [16]. Some researchers in IDs have highlighted the need to consider data protection concerns which would support privacy. Despite the benefits derived from the implementation of national identification cards – preventing identity theft and terrorism – some also argue that the benefits derived are outweighed by security risk [17]. One study conclude that, after the 9/11, Americans have tried to introduce a national identity card but they are still concerned about the possible loss of privacy looking at the authorized and unauthorized use of the information collected [18]. Another study predicted that looking at the wide use of RFID and smart card technologies which aids in the collection of information on people, governments would have no choice than to put some regulations on how these technologies are used since they pose threat to privacy [19].

B. Privacy Theories

Because privacy does not have a definite arena it operates, several disciplines (philosophy, psychology, political science, information technology), have examined it in different perspectives. Philosophy tries to present the obscure foundation of privacy. Political science presents privacy as a social issue that requires some kind of public policy solutions; and Psychology presents privacy as the mechanism for controlling and protecting information [20].

Tavani [21] categorized the theories of privacy into three; non-intrusion, seclusion, and control or limitation. The first one, non-intrusion privacy theory defines privacy as a natural right that an individual should own. Such rights include the right to "be let alone" or the right to be free from government intrusion. This type of privacy was first proposed by Louis Brandeis and Samuel Warren in their article "The Right to Privacy" [22]. The second, seclusion theory of privacy defines privacy as the means where an individual separate him/herself from others and restrict or eliminate entirely the opportunities for an individual to be observed by another person. The last part of the three categories, control or limitation (as seen by most theorists as identical concepts) defines privacy as controlling how personal information about an individual is accessed.

Another broad classification of privacy as presented in [16] is normative and descriptive privacy. In the normative privacy theory, individuals are protected by some form of cultural norms which include formal laws or informal polices. Sometimes, this normative privacy theory is extended into zones or context where needed (e.g. a patient in consultation with a doctor). Descriptive defines privacy the same way Tavani defines seclusion privacy theory.

Nissenbaum proposes a contextual integrity theory of information privacy as presented in [16]. In her theory, she sees right to privacy as neither secrecy nor controlling who has access to an individual's personal information but as an appropriate way to flow personal information. She proposes a "context relative informational norm" that helps to govern activities in a context. She characterized these norms with four key parameters: contexts, actors, attributes, and transmission principles.

Tavani and Moor through a series of publications proposed a hybrid privacy theory as presented in [16] where they seek to provide a theory that goes beyond the early privacy theories. In their theory, they present a model that describes a privacy theory and they suggested three core aspect: concept of privacy, justification of privacy, and management of privacy.

III. Design and Implementation

In this section, we will show the design and implementation of our privacy enhanced identification system where the privacy of the cardholder is factored into the design. The model of the system in shown in **Figure 1** below.

A. Database Layer

This layer is responsible for storing all the data that would be generated by the system. It consists of a distributed database management system (DDBMS) that manages a cluster of relational databases. This distributed nature of the database is meant to improve response time. Thus, through the use of database replication, one master database can be written to and other slave databases would be read from. Secondly, it will support horizontal scaling which would allow us to improve the performance of the system by adding more resources to the cluster without difficulty. For some security purposes (unauthorized access to the database), most of the data in the database are encrypted with the exception of those used to lookup records.

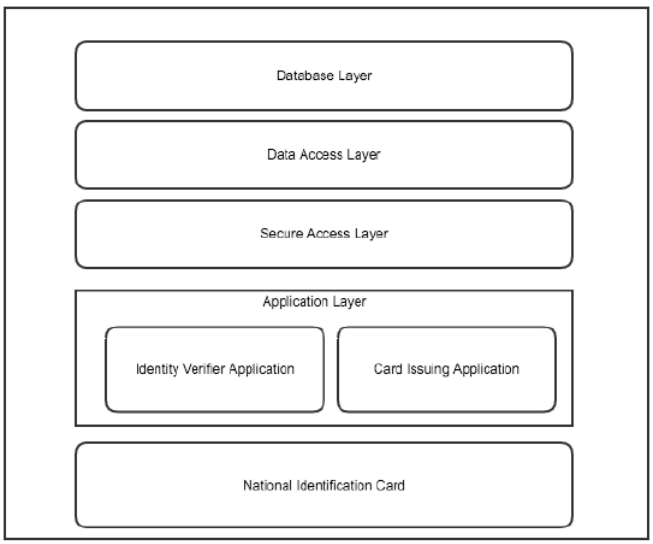

Figure 1: System conceptual model

B. Data Access layer

This layer contains all the logic used to interact with the card, the application and the database. It was implemented using Laravel. This is a PHP Model View Control framework. Based on the framework, an Application Programming Interface (API) was developed which used Representational State Transfer (REST) to communicate with the application layer over HTTP. Aside defining and controlling the communication protocol between the database layer and the application layer, the data access layer also contains majority of the important logic that is used to facilitate the operation of the system. Two of the significant ones that will be highlighted below are the card code generation and the verification code generation.

1) Card Code Generation

For every card that is generated, a unique card code is assigned to it. This was achieved by implementing a 14-character alphanumeric code generation algorithm that could potentially generate over three billion unique card codes every year.

2) Verification Code Generation

This is the code that is used by a cardholder to allow a verifier to be able to verify his/her details on the card. The code is generated by using a random function based on the current timestamp and finally hashed using MD5 hashing algorithm. The first four characters of the hashed value are extracted, saved into the database, and sent to the cardholder. This code is valid for 30 minutes after which a new code would have to be generated.

3) Generation of the Application ID and Token

The application ID and token plays an essential role in enabling and securing communication between any application in the application layer and the API in the data access layer. The application token is used for any remote call by both the card issuing application and the verification application. It is generated randomly to prevent it from been forged and it expires every one hour.

The application ID is created by the security layer and it is created once and used throughout the life time of the application.

C. Secure Access Layer

This layer is responsible for encrypting and decrypting all data to and from the database. Aside that it also ensures that only requests from authorized applications are served. This is enabled by ensuring that all client applications possess a token that would be validated before requests are handled. This token is first provided to the client application upon initialization and stored in the application for further use till it has expired and requires renewal.

1) Encryption of Data

The encryption was achieved using a combination of OpenSSL cryptographic library and a 256 bit AES CBC encryption algorithm provided by the MVC framework. To determine whether there has been any change in the encrypted data, each value encrypted is again signed using Message Authentication Code (MAC).

2) Secure Token Management

This was implemented in the form of a middleware. This middleware listens to calls to the API URLs on the server and authenticate them to ensure they are coming from authorized applications. A call to any API URL should include three parameters in their header: appType, this indicates which application is making the call (card issuing application or card verification application), appToken, this is used together with the appID parameter to check against the verifier or card issuer table in the database to confirm that it is authentic and that it belongs to the application requesting access to the database.

D. Application Layer

This layer contains two main applications; the card issuing application used by the card issuing authority and the card verification application used in verifying the cardholder. These two applications can be implemented in different ways so far as the applications can interface directly or indirectly with card and consume the services provided by the data access layer. The two applications were implemented on a proof of concept basis using largely available mobile technology in the form of a custom Android application developed to run on Android devices which support near field communication (NFC). The applications would still be supported on android devices without NFC. Special NFC reader could be procured and interface with any android device through Bluetooth or the audio jack of the device.

E. Identification Card

The identification card was design to show little or no information about the cardholder. Any other information about the cardholder is encrypted and stored in an inbuilt chip on the card. The card used is the MIFARE DESFire 8K NFC card. It has an 8KB onboard non-volatile memory and communicates wireless through NFC. It is passive in nature. Thus, it draws power from the energy of the radio antenna of the reader, in this case the Android powered device during operation. It stores data in the NFC Data Exchange Format (NDEF) format and can transfer data as fast as 848kbit/s. In order to read from or write to the card, it would have to be brought very close to (or even touch) the NFC antenna of the reader.

F. Verification Methods

Both the card issuing application and card verification application can perform card verification. The purpose of this work is to give verification control to the cardholder who at any point can grant or revoke access to his information stored on the card. To achieve this, a two factor authentication was introduced. To initiate the verification process, the card is brought closer or in direct contact with the application, then a four-digit code is generated and sent to the cardholder's phone. With this code, the cardholder can either grant access to the verifier or revoke access. The code is generated using a random function in PHP based on the current time. The generated random code is then hashed with MD5 hashing algorithm and the first four-digits are extracted and sent to the cardholder through SMS together with a unique number. The unique number is associated with a particular verifier. The code generated together with the ID of the verifier are stored in the database together with the timestamp and it is linked to the cardholder's details. Again a flag is set to indicate that the verifier has access to view the details of the cardholder. The total time to live (TTL) for the code generated is 30 minutes after which a new code would have to be generated. The cardholder then gives the code to the verifier to be entered. The code is then sent to the data access layer where it is checked whether 30 minutes has passed since the code was generated. Without this code, the verification of the cardholder is not possible. This code can be given to multiple verifiers so far as the TTL for the code has not expired. The card holder verification process is depicted in the sequence diagram in **Figure 2**.

G. Revoking Access

Even though the TTL of the code is 30 minutes, the cardholder can at any point in time revoke the access that has been granted to a verifier. This is done through SMS. The cardholder texts the unique number that was sent to his phone when the code was generated to a code which is sent to the data access layer and finally set the flag associated with that unique number to deny further access. This then denies the verifier linked to that unique number further access to any information about the cardholder. The sequence diagram in **Figure 3** shows the access revocation process.

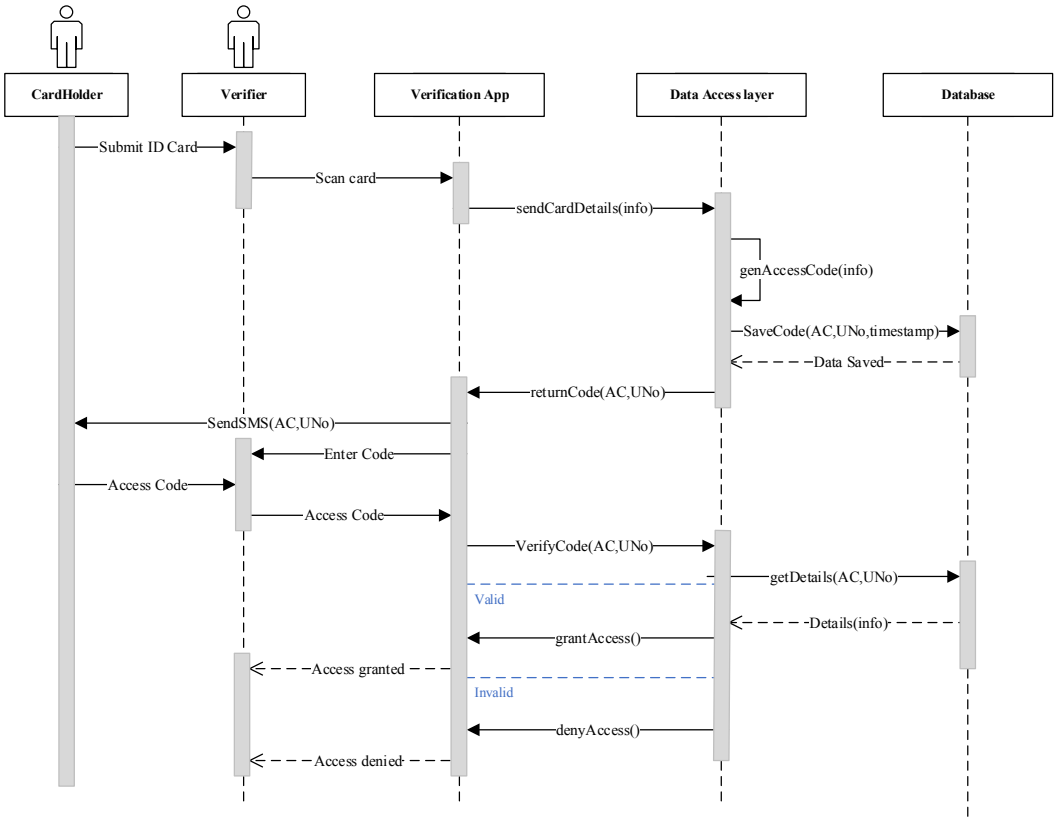

Figure 2: Sequence diagram for card holder verification process

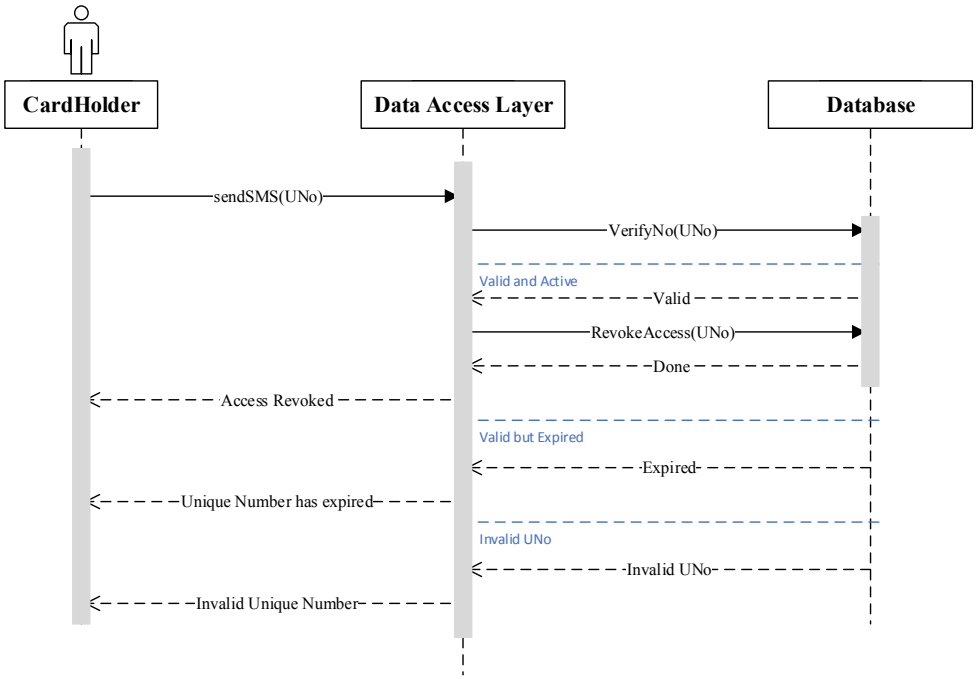

Figure 3: Sequence diagram for access revocation process

IV. Evaluation

Evaluation was done by using automated unit testing. PHP Unit testing framework was used. Most of the testing that was done were sending request to the API in order to ensure that they provided the appropriate response. Some of the tests also covered unique algorithms such as those for card code generation, verification code generation, etc. In developing the mobile applications, testing was achieved by using the Junit testing framework. For tests that required access to the internet or other limited resources, they were mocked using the Mockito mocking framework for Android. The completed proof of concept implementation of the system has also been tested and found to meet the requirement specifications of the system and the objectives set out for the project.

V. Conclusion

It has been identified that the current nature of national ID card systems being used all over the world pose a credible threat to the privacy of the cardholder. This is because the details of the cardholder are openly displayed on the card and thus make the card susceptible to falsification and fraudulent use. This paper has argued that the motivation for undertaking this research project is because of the failure of various countries to implement national ID systems with a strong privacy theory backing the implementation even though there is a collective consensus to have such a system is place. Secondly, it is aimed at addressing the privacy concerns of those countries debating national identification system adoption. Finally, because the cost implications of implementing security and privacy enhancing national ID card systems are normally out of reach of most developing and even developed countries, the project sought to design and develop a national identification system that is suitable for implementation at minimal cost per capita to any country. Based on the control and limitation theory of privacy, our proposed privacy enhancing national identification card system was designed and developed to achieve the objectives of restricting unauthorized access to information on the ID card, and giving the cardholder control over who has access to information on the ID card.

References

[1] E. P. I. Electronic Privacy Information Center, "EPIC - National ID and the REAL ID Act," Dec-2015. .

[2] "Mandatory National IDs and Biometric Databases," Electronic Frontier Foundation, 2016. .

[3] A. Juels, D. Molnar, and D. Wagner, "Security and Privacy Issues in E-passports," in First International Conference on Security and Privacy for Emerging Areas in Communications Networks (SECURECOMM'05), 2005, pp. 74–88.

[4] M. J. Quinn, Ethics for the Information Age, 6 edition. Boston: Pearson, 2014.

[5] A. Acquisti and J. Grossklags, "Privacy and Rationality in Individual Decision Making," IEEE Security & Privacy, vol. 3, no. 1, pp. 26–33, 2005.

[6] I. Naumann et al., "Privacy Features of European eID Card Specifications — ENISA," Jan-2009. .

[7] I. Naumann and G. Hogben, "Privacy features of European eID card specifications," Netw. Secur., vol. 2008, no. 8, pp. 9–13, Aug. 2008.

[8] S. Arora, "National e-ID card schemes: A European overview," Inf. Secur. Tech. Rep., vol. 13, no. 2, pp. 46–53, May 2008.

[9] A. Pfitzman and M. Hansen, "Anonymity, Unobservability, Pseudonymity, and Identity Management A Proposal for Terminology." .

[10] "What is identity theft? - Definition from WhatIs.com," SearchSecurity. .

[11] A. M. Al-Khouri, "UAE National ID Programme Case Study," Int. J. Soc. Sci., vol. 1, no. 2, pp. 62–69, 2007.

[12] S. S. Lim, H. Cho, and M. R. Sanchez, "Online privacy, government surveillance and national ID cards," Commun. ACM, vol. 52, no. 12, pp. 116–120, 2009.

[13] A. M. Al-Khouri, "PKI IN GOVERNMENT IDENTITY MANAGEMENT SYSTEMS," Internatioal J. Netw. Secur. ITS Appl., vol. Vol 3, no. May, 2011.

[14] M. H. Mohd Shukri, "The Privacy and Security of An Identification Card:Malaysia Perspective," Munich Pers. RePEc Arch., no. 35423, 2015.

[15] R. Gellman, "Privacy and Biometric ID Systems : An Approach Using Fair Information CGD Policy Paper 028 August 2013," Cent. Glob. Dev., no. August, 2013.

[16] J. Heath, "Contemporary Privacy Theory Contributions to Learning Analytics," J. Learn. Anal., vol. 1, no. 1, pp. 140–149, 2014.

[17] S. R. Hiltz, H.-J. Han, and V. Briller, "Public Attitudes towards a National Indentity 'Smart Card:' Privacy and Security Concerns," Proc. 36th Hawaii Int. Conf. Syst. Sci., vol. 5, no. C, p. 139a (1-8), 2003.

[18] P. G. Neumann and L. Weinstein, "Risks of National Identity Cards," Commun. ACM, vol. 44, no. I, p. 176, 2001.

[19] a. N. Joinson, "Watching me, watching you: privacy attitudes and reactions to identity card implementation scenarios in the United Kingdom," J. Inf. Sci., vol. 32, no. 4, pp. 334–343, 2006.

[20] T. Elder, F. W. Yarrison, and B. L. Long, "Title : An Empirical Investigation of Privacy : The Impact of Multiple Levels of Trust," pp. 1–24, 2015.

[21] H. T. Tavani, "Philosophical Theories of Privacy: Implications for an Adequate Online Privacy Policy.," Metaphilosophy, vol. 38, no. 1, 2007.

[22] S. D. Warren and L. D. Brandeis, "The Right to Privacy," Harv. L. Rev., vol. 4, no. 5, pp. 193–220, 1890.